# Starting Definitions

**Risk:** High possibility of a harmful event occurring (probability)
Probability makes it predictable as the ability to prevent is based on the ability to predict. That ability depends on the skills and knowledge regarding the causal chain that leads to an event.

**Proactivity:** Techniques and methodologies aimed at prevention.
Proactivity is the foundation of Risk Management.
If unpredictable then we aim to eliminate or mitigate consequences.

**Information & Taxonomy:** Risk prevention relies on data and information.
Information is described as structured aggregation of data which requires understanding its semantics and the network of data it aggregates.
Instead, Taxonomy is the hierarchical ordering of data within the context of information and its context of discourse. (Relationships between data)

**Unity & Uniqueness:** In data we have two fundamentals: Signifier, Meaning.
Where:
- Signifier is the external form.
- Meaning is its content.

Also:

**Harmony**: World is ordered, links different elements and unites them from a single structure, finds its own composition and gives raise to beauty. ("monos" that means one)

**Kosmo**: Order and Beauty of the world, governed and interpretable by rules.

**The Word**: Connective tissue that allows the world to be reflected in a man, making conscious thought and communication possible.
No words → No social unity.

**Signifier & Signified**: Signifier is the phisical form (sound that the mouth says) and Signified is the concept (representation of the boor)
Thanks to the correlation between sound and concept, comprehension occurs; so Denotation is crucial.

**Denotation**: The action by which a word works as a pointer to the single and agreed-upon meaning of a word by a group's shared social and cultural knowleadge.

**Sense & Meaning**: Expressing emotions is another reason we communicate.
Sense is the presentation, or the path your mind takes to get to the meaning. (The winner of / The loser of)

**Dinamics of communication**: The talker uses the shared words of the group and the listener extrats the meaning from the social context.

**Interpretation**: The communication level turns subjective. To comprehend a polysemic word (more meanings) asks for crucial context.

**Omission**: The law sanctions the non-transition towards the required action.

↳ Proper: When inertia is the direct violation of a norm.

↳ Improper: When the mean to commit and offense is the lack of activity.

-> T factor: Action or omission of the subject. ("muscolar level")

-> K factor: Conscious factor or psychic impulse of a subject.

**Causal Link**: First step to determine the subjects responsability

↳ T factor of the subject must be the cause of the fact.

↳ Excluded responsability if other factors (other than T) could produce the fact on their own

**Foundation of Guilt**: After confirming the subject committed the fact, we establish the K factor in which it was committed.

**Psicological element**: Was it comitted with:?

↳ Intent (Dolo): Foreseen result by the agent.

↳ Fault (Colpa): Not wielded but caused through negligence, imprudence, inexperience or non-compliance with law.

~~Elements of the offense~~ **What is Jus? PT. 3**

A fact only constitutes an offense only if it falls within the Typical fact. To understand if it does we must consider:

↳ Typical fact as a model or template

↳ historical fact as an instance of the model

↳ Relashionship between historical and abstract model (subsumption)

We first check the linguistic verification, checking the meaning of the historical fact to the one of the typical fact.

# Concurrence of Crimes

↳ Formal concurrence: Commits multiple crimes with the same action
↳ Material concurrence: Commits multiple crimes ~~with~~ at different times.
↳ Continuous offense: Formal + material. Multiple crimes, even at different times, in execution of the same criminal design.

Concurrence of Crimes: Some person commits multiple crimes
Concurrence of Penal norms: When a single action falls in the description of multiple ~~crimes~~ penal norms.

Concurrence of people in Crime: multiple people participate in the same crime. Each has to participate with T or K factor.

Attempted Crimes are different crimes compare to the consumated crimes.

## Justifications

↳ Fortuitous event: unforseeable event.
↳ Forza maggiore: subject becomes a mechanism of the fact.
↳ Phisical constraint: being forced to act.
↳ Consent of the entitled: if given consent AND not an inalienable right (death)
↳ Fulfillment of Duty: lack of coherence of legal system (Jornalist report right)
↳ Motive: legitimate defense if without excess.
↳ Necessity: necessity of saving themselfs
↳ legitimate defense: balance between aggressors sacrifice and exposed for victim.

# Why GDPR is important?

1. Accountability: they must demonstrate compliance at anytime, so they must perform proactive Risk management.

2. Data as an asset: they recognize personal data as an extension of the natural person.

3. Empowerment of Subjects: giving the right to be forgotten (to delete data), and data portability to have the right to switch providers and move one's digital data.

## Principles for every Risk Assessment

- Lawfullness, Fairness, Transparency: No hidden processing.
- Purpose limitation: Data for purpose A can't be used for purpose B without consent.
- Data minimization: Collect only what is necessary.
- Storage limitation: Delete data when purpose is fulfield.
- Integrity and Confidentiality: Prevent data breaches.

## International Data Transfer

The GDPR treats as international transfers all transfers from or to the outside of the European Economic Area (EEA).

Conditions:

1. Adequacy: transfer allowed if the third country if the European commission has established it as an adequate level of protection.
2. Appropiate safeguards: in the absence of an adequacy decision, the transfer is possible if the Data controller or Processor provide appropiate safeguards.
3. Derogations: Transfer allowed only in special cases like explicit consent, public interest, or performance of contract...

limitations of NIS1 :

↳ Different approaches from members.
↳ Uneven application of obbligations.
↳ Fragmentation of the internal market.
↳ Lack of consistency in supervision.
↳ Many uncovered critical sectors.
↳ Reduced response capacity for major incidents (Covid..)

## NIS 2

Systemic reform made in 2022 after covid with many introductions:

1. New Classification of regulated entities: eliminates OES/DSP and introduced: Essential entities and important entities. Is generally size-based, but small entities with high risk can be included.
2. Expansion of covered sectors: included sectors like: food sector, postal, waste management, chemical and medical device industries, ....
3. Risk Management obligations: mandating 10 minimum measures: incident man., supply chain security, vulnerability management, auth, encryption, business continuity..
4. Structured 3-phase notifications: Early warning (24h) -> Full notification (72h) -> Final Report (within 1 month)
5. Harmonized European sanctions regime: Where Essential entities pay up to 10 M.€ or 2% of global turnover, while Important entities pay up to 7 M.€ or 1.4%.
6. Advanced European Governament: Streangthening CSIRT, EU-CyCLONe for large-scale risk management, EU cordinated vulnerability Disclosure, central role for ENISA.

Zatti

## ISO 27005

Presents a simplified form where Risk Assessment is the sum of Identification, Analysis and Evaluation.

Is a guidance for managing information security risks in conformity with ISO 27001. It doesn't prescribe a specific methodology but rather a general framework applicable to any organization.

Promotes an iterative approach PDCA (Plan-Do-Check-Act), to ensure continuos improvement.

Important Criteria to consider:

- Risk evaluation criteria
- Impact criteria
- Risk Acceptance criteria

### Workflow

1. Description of ISRA: Define the context, where we decide the basic criterias, then identify, describe and prioritize risks.
2. RA: Identification of asset: identify all available info on assets, creating the list of assets and of associated business processes.
3. RA: Identification of Threats: study information on possible threads, creating a catalogue of threads, its source and type.
4. RA: Identification of existing controls: check documentation of existing controls and Risk Treatment Plan (RTP). (abbiamo le difese e lo status implem)
5. RA: Id. of vulnerabilities: cross-reference between previous Asset, Treat and existing controls, this creates a vulnerability list.
6. RA: Id. of Consequences: evaluate possible impact on the triad CIA.
7. RA: Risk estimation: take previous info and use qualitative or quantitative scales to categorize them.

Use cases: ISO 27005

-> Lets start by defining context: We mention what we have in this context and then explore our objective of this analysis.

-> Risk Identification: We start with Assets (what do we own and need to protect), then the threats (are they cyber or physical) Next the vulnerability (Maybe some service in use can be backdoore

-> Risk Evaluation: Is the impact of the calculated risk irrelevant or critical (breaks some of the CIA triad). Does the prob. of the thread expect to change.

-> Risk Treatment: Can we fix it? maybe Retention, reduction, share, avoidance

NIST SP 800-53:

It can't be used for organizational risk assessment, it focuses on technical infrastructure. (federal information system)

↳ Prescriptive -> no asset identification (context)

↳ Use it when IT infrastructure

OCTAVE:

Information assets are its focus, its designed to be self-directed.

↳ establish criteria -> Profile assets -> Identify threats -> Identify risks ->
-> Mitigate risks. (asset centric)

EBIOS:

Focuses to identify Feared Events and Tyrets scenarios and focuses how an attacker might attack. (Path)